

Clase 226 — Ataques y pentest en entornos cloud

Parte: **10 — Seguridad en la nube y contenedores** · Fuente: *MITRE ATT&CK for Cloud (IaaS matrix)* y *Rhino Security Labs — AWS Pentesting research* 🕒 Duración estimada: **150 min** · Nivel: **Avanzado**

⚠️ **Aviso ético.** Esta clase enseña técnicas ofensivas. Prácticalas **únicamente en tu propia cuenta de laboratorio o con autorización escrita y explícita del propietario**. El pentest de la nube además requiere respetar las políticas de pruebas del proveedor. Atacar recursos ajenos es ilegal.

🎯 Objetivo

Aprender la metodología de pentest en la nube: reconocimiento, enumeración de recursos e IAM, explotación de misconfiguraciones (credenciales expuestas, buckets, metadatos, roles), escalada de privilegios, movimiento lateral y persistencia, todo mapeado a MITRE ATT&CK for Cloud.

📄 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Enumerar** recursos y permisos de una cuenta a partir de credenciales de acceso limitado.
2. **Explotar** el servicio de metadatos de instancia (IMDS) para robar credenciales de rol.
3. **Escalar** privilegios aprovechando permisos IAM peligrosos.
4. **Identificar** persistencia y movimiento lateral en la nube.
5. **Mapear** cada técnica a una táctica de MITRE ATT&CK for Cloud.

📖 Temas

#	Tema	Por qué importa
1	Reconocimiento externo	OSINT, buckets y subdominios expuestos
2	Credenciales filtradas	Vector de entrada más común
3	Enumeración IAM	Descubrir qué se puede hacer con lo que hay
4	Abuso de metadatos (IMDS/SSRF)	Robo de credenciales de rol de instancia
5	Escalada de privilegios	De acceso limitado a administrador
6	Movimiento lateral y persistencia	Mantener acceso y expandirse
7	Mapeo a MITRE ATT&CK Cloud	Lenguaje común para reporte

📖 Definiciones y características

- **IMDS (Instance Metadata Service):** endpoint local `169.254.169.254` que entrega credenciales del rol de la instancia. *Clave:* IMDSv2 con tokens mitiga el abuso por SSRF.

- **SSRF hacia metadatos:** forzar a la app a pedir el endpoint de metadatos. *Clave:* clásico vector para robar credenciales en la nube.
- **Enumeración IAM:** listar permisos propios con `iam:SimulatePrincipalPolicy` o fuerza bruta de APIs. *Clave:* define el mapa de ataque.
- **Persistencia:** crear usuarios/claves/roles ocultos o backdoors en funciones. *Clave:* sobrevive a la rotación de la credencial inicial.
- **Pacu:** framework de explotación AWS con módulos de enum y escalada. *Clave:* automatiza tácticas comunes en laboratorio.
- **CloudGoat/CloudFoxable:** entornos vulnerables intencionados para practicar. *Clave:* seguros y legales para entrenar.
- **MITRE ATT&CK for Cloud:** matriz de tácticas/técnicas específicas de nube. *Clave:* estandariza el reporte.

Herramientas y preparación

- **Pacu, ScoutSuite, PMapper, enumerate-iam**, y las CLIs oficiales.
- **CloudGoat** (Rhino Security Labs) para desplegar escenarios vulnerables en TU cuenta de laboratorio.
- Un entorno aislado y presupuesto controlado (los recursos cuestan dinero).

```
# Desplegar un escenario vulnerable de laboratorio
python3 cloudgoat.py create iam_privesc_by_rollback
# Enumerar permisos de una credencial obtenida (en laboratorio)
enumerate-iam --access-key AKIA ... --secret-key ...
```

Laboratorio guiado

Todo se ejecuta en tu **cuenta de laboratorio** con CloudGoat. No apuntes a infraestructura ajena.

1. Despliega el escenario `iam_privesc_by_rollback` de CloudGoat; recibirás credenciales de acceso limitado.
2. **Reconocimiento IAM:** con `enumerate-iam` y `aws iam get-user`, mapea qué permisos tienes.
3. Identifica el permiso peligroso (p. ej. `iam:CreatePolicyVersion` con `--set-as-default`) que permite reescribir una política.
4. **Escala:** crea una nueva versión de una política adjunta a tu usuario que conceda `*:*` y márcala por defecto; verifica que ahora eres admin.
5. Repite con el escenario `ec2_ssrf`: explota una app con SSRF para leer `http://169.254.169.254/latest/meta-data/iam/security-credentials/` y roba las credenciales del rol.
6. Usa esas credenciales para enumerar y acceder a un bucket S3 (movimiento lateral).
7. **Mapea** cada paso a MITRE ATT&CK for Cloud (Initial Access, Discovery, Privilege Escalation, Lateral Movement).
8. **Remedia:** activa IMDSv2 obligatorio, aplica permission boundaries y elimina el permiso de escalada. Repite el ataque y confirma que falla.
9. Destruye el escenario con `cloudgoat destroy` para no dejar recursos ni coste.

Ejercicios

1. Enumera todos los roles asumibles desde una identidad dada con PMapper.
2. Explica por qué IMDSv2 mitiga el robo de credenciales por SSRF.
3. Redacta la sección de "escalada de privilegios" de un informe de pentest con evidencias.
4. Identifica tres técnicas de persistencia en AWS y su detección en CloudTrail.
5. Resuelve otro escenario de CloudGoat y documenta el kill chain.
6. Diseña una regla de detección para la creación anómala de claves de acceso IAM.

Reto verificable

Resuelve de principio a fin un escenario de CloudGoat que empiece con acceso limitado y termine en administrador, documentando el camino y luego aplicando las remediaciones que lo cierren.

Criterio de aceptación: el informe incluye cada paso con el comando usado, la técnica ATT&CK correspondiente y la evidencia; tras aplicar las remediaciones, reejecutar el ataque falla en el punto de escalada.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
AccessDenied al enumerar	Permisos realmente mínimos; prueba rutas indirectas (assume-role, passrole).
Metadatos devuelven 401	IMDSv2 activo; necesitas un token PUT primero, o el ataque está mitigado.
Recursos de CloudGoat siguen facturando	Olvidaste <code>ccloudgoat destroy</code> ; destrúyelos siempre al terminar.
El proveedor bloquea el escaneo	Actividad marcada como abuso; respeta la política de pentest del proveedor.
No hay evidencia para el informe	No se registró la salida; captura comandos y respuestas desde el inicio.

Preguntas frecuentes

? ¿Necesito permiso del proveedor para hacer pentest en la nube? Depende. Muchas pruebas a tus propios recursos están permitidas sin aviso previo, pero ciertas actividades (p. ej. stress/DoS) requieren autorización. Revisa siempre la política de pruebas del proveedor y ten permiso escrito del dueño de la cuenta.

? ¿Por qué el robo de credenciales de instancia es tan crítico? Porque el rol de la instancia suele tener permisos amplios; con esas credenciales el atacante actúa como el servicio legítimo, sin contraseña que romper. Por eso IMDSv2 y roles mínimos son clave.

? ¿CloudGoat es seguro para practicar? Sí, despliega recursos vulnerables **en tu propia cuenta** de forma intencionada y reproducible. Aun así, aíslalos y destrúyelos al terminar para evitar exposición y coste.

Referencias

- MITRE ATT&CK — Cloud Matrix (IaaS). <https://attack.mitre.org/matrices/enterprise/cloud/>
- CloudGoat (Rhino Security Labs). <https://github.com/RhinoSecurityLabs/cloudgoat>
- Pacu — AWS exploitation framework. <https://github.com/RhinoSecurityLabs/pacu>
- AWS — Use IMDSv2. <https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/configuring-instance-metadata-service.html>
- Rhino Security Labs — AWS privilege escalation. <https://rhinosecuritylabs.com/aws/aws-privilege-escalation-methods-mitigation/>

Siguiente clase

Clase 227 - Seguridad de contenedores: Docker